

VENDOR RISK ASSESSMENT

Third-Party Security & HIPAA Compliance Evaluation

CONFIDENTIAL

Vendor	ClearPath Health, Inc.	Date	June 2026
Service	Cloud Telehealth SaaS — Virtual visits, EHR integration, Remote monitoring	Analyst	Maximilian Rivera, GRC Analyst
Requesting Org	Lakewood Regional Medical Center	BAA Status	Draft — Pending Legal Review
Data Processed	ePHI · PII · Payment data (Stripe)	Hosting	AWS GovCloud (primary) / Azure (DR)
Certifications	SOC 2 Type II (2025) · HITRUST CSF (in progress)	Risk Rating	HIGH — Conditional Approval Required

EXECUTIVE SUMMARY

ClearPath Health, Inc. is a cloud-based telehealth platform seeking onboarding as a Business Associate under HIPAA for Lakewood Regional Medical Center. This assessment evaluated security posture across HIPAA Security Rule safeguards, ISO 27001:2022 Annex A controls, and SOC 2 Type II trust service criteria using a 40-question questionnaire and review of submitted documentation including the SOC 2 report, security policies, and penetration test summary.

The assessment identified **12 total findings — 3 Critical, 4 High, 3 Medium, 2 Low**. Three Critical findings present unacceptable risk for immediate onboarding: no MFA on administrative accounts, two subprocessors handling ePHI without executed Business Associate Agreements, and no HIPAA-compliant incident response plan. The vendor is **not recommended for immediate onboarding**. A conditional 90-day approval pathway is outlined in Section 6.

Frameworks Evaluated	Methodology	Assessment Period
HIPAA Security Rule (45 CFR Part 164) ISO 27001:2022 Annex A SOC 2 Type II (AICPA TSC)	40-Question Security Questionnaire SOC 2 Type II Report Review Policy & Pen Test Documentation	Questionnaire: May–June 2026 Documentation Review: June 2026 Report Date: June 20, 2026

3 CRITICAL

4 HIGH

3 MEDIUM

2 LOW

12 TOTAL
FINDINGS

1. Vendor Profile & Assessment Scope

Company	ClearPath Health, Inc.	Hosting	AWS GovCloud (primary) · Azure (DR)
Service	Cloud-based telehealth: virtual visits, remote monitoring, EHR API integration	Employees	~180 total (40 in engineering/security)
Subprocessors	Twilio (video/messaging) · Stripe (billing) · Okta (identity)	Certs	SOC 2 Type II (2025) · HITRUST CSF (in progress)

Methodology: 40-question security questionnaire · SOC 2 report review · Security policy documentation · Penetration test summary. Frameworks: **HIPAA Security Rule (45 CFR Part 164)** · **ISO 27001:2022 Annex A** · **SOC 2 Type II (AICPA TSC)**.

2. PHI Data Classification

Data Element	PHI?	Risk Tier	Transmission	Encrypted at Rest
Patient Name	Yes	High	API / TLS 1.3	AES-256
Date of Birth	Yes	High	API / TLS 1.3	AES-256
Diagnosis Codes (ICD-10)	Yes	Critical	API / TLS 1.3	AES-256
Video Visit Recordings	Yes	Critical	Encrypted stream	S3 SSE-KMS
Prescription History	Yes	Critical	API / TLS 1.3	AES-256
Payment Card Data	No*	High	Stripe token	Tokenized (PCI DSS)
IP Address / Device ID	Yes	Medium	HTTPS logs	AES-256
Email Address	Yes	Medium	SMTP / TLS	AES-256

*Payment card data is PCI DSS scope via Stripe; excluded from HIPAA PHI classification.

3. Security Questionnaire Results (40 Questions · 6 Domains)

Domain	Total	Compliant	Partial	Non-Compliant	Score
Access Control & IAM	8	5	2	1	75%
Data Protection & Encryption	7	6	1	0	93%
Incident Response	6	3	1	2	58%
Vulnerability Management	6	4	1	1	75%
Business Continuity / DR	6	3	2	1	67%
Third-Party / Subprocessor Mgmt	7	3	2	2	57%
TOTAL	40	24	9	7	71%

4. Findings (3 Critical · 2 High shown in detail below)

VRA-001	Critical	No MFA on Administrative Accounts	HIPAA: §164.312(d)	ISO: A.8.5	SOC 2: CC6.1	Score: 20
		MFA is not enforced on administrative and privileged accounts in production. Single-factor authentication exposes ePHI to credential stuffing, phishing, and brute force. Highest-priority access control gap identified.				
		Action: Enforce MFA on all admin accounts via IdP configuration within 30 days. Provide configuration evidence to LRMC.				
VRA-002	Critical	No HIPAA Incident Response Plan	HIPAA: §164.308(a)(6)	ISO: A.5.26	SOC 2: CC7.3	Score: 20
		No documented IR plan addresses the HIPAA Breach Notification Rule 60-day reporting timeline. Incident handling is entirely ad hoc with no defined roles, escalation paths, or PHI containment procedures.				
		Action: Develop a HIPAA-compliant IR plan within 60 days. Must include breach notification workflow, named incident owner, and 60-day reporting trigger.				
VRA-003	Critical	Subprocessors Without Executed BAAs	HIPAA: §164.308(b)	ISO: A.5.19	SOC 2: CC9.2	Score: 20
		Twilio (video/messaging) and Stripe (billing) process PHI in transit but have no executed BAAs. HIPAA §164.308(b) requires all subcontractors who handle PHI on behalf of a BA to be under a signed agreement.				
		Action: Execute BAAs with Twilio and Stripe before provisional onboarding proceeds. 15-day hard deadline.				
VRA-004	High	Penetration Test Overdue (18 months)	HIPAA: §164.308(a)(8)	ISO: A.8.8	SOC 2: CC4.1	Score: 12
		Last third-party pen test was December 2024 — now 18 months old. Annual testing required under HIPAA §164.308(a)(8) Evaluation and SOC 2 CC4.1 for all vendors processing PHI.				
		Action: Commission a new third-party penetration test within 90 days. Deliver executive summary including scope and all critical/high findings.				
VRA-005	High	No Quarterly Privileged Access Review	HIPAA: §164.308(a)(3)	ISO: A.8.2	SOC 2: CC6.2	Score: 12
		No formal quarterly access review program exists. Privileged accounts are not audited on a recurring basis, creating ongoing risk of orphaned accounts, privilege creep, and unauthorized ePHI access.				
		Action: Implement and document a quarterly access review program within 30 days. Provide most recent completed review results.				

5. Framework Compliance Summary

Control Area	HIPAA Reference	ISO 27001	SOC 2	Status
Multi-Factor Authentication	§164.312(d)	A.8.5	CC6.1	NON-COMPLIANT
Encryption at Rest	§164.312(a)(2)(iv)	A.8.24	CC6.7	COMPLIANT
Encryption in Transit	§164.312(e)(2)(ii)	A.8.24	CC6.7	COMPLIANT
Access Control Policy	§164.312(a)(1)	A.5.15	CC6.1	PARTIAL
Quarterly Access Review	§164.308(a)(3)	A.8.2	CC6.2	NON-COMPLIANT
Incident Response Plan	§164.308(a)(6)	A.5.26	CC7.3	NON-COMPLIANT
Breach Notification Process	§164.400–414	A.5.26	CC7.4	NON-COMPLIANT
Vulnerability Management	§164.308(a)(1)	A.8.8	CC4.1	PARTIAL
Penetration Testing	§164.308(a)(8)	A.8.8	CC4.1	PARTIAL
BA / Subprocessor Agreements	§164.308(b)	A.5.19	CC9.2	NON-COMPLIANT
Business Continuity Plan	§164.308(a)(7)	A.5.29	A1.2	PARTIAL
Disaster Recovery Testing	§164.308(a)(7)	A.5.30	A1.3	COMPLIANT
Security Awareness Training	§164.308(a)(5)	A.6.3	CC1.4	COMPLIANT
Audit Logging	§164.312(b)	A.8.15	CC7.2	COMPLIANT
Data Retention & Disposal	§164.310(d)(2)	A.8.10	CC6.5	COMPLIANT

7 Compliant · 4 Partial · 5 Non-Compliant | 47% fully compliant · 73% partially or fully compliant

6. Risk Rating & Recommendation

Severity	Count	Key Findings
Critical	3	No MFA on admin accounts · No executed BAAs with Twilio/Stripe · No HIPAA IR plan
High	4	Penetration test overdue (18 mo.) · No quarterly access review · Weak BYOD controls · Retention gaps
Medium	3	Incomplete BCP documentation · Partial audit log coverage · No formal change management
Low	2	Annual security training not yet tested · Informal vendor offboarding procedure

CONDITIONAL APPROVAL — 90-Day Remediation Plan Required

ClearPath Health demonstrates strong encryption, audit logging, and disaster recovery posture. However, three Critical findings present unacceptable PHI exposure risk for immediate onboarding.

Before provisional onboarding: (1) Execute BAAs with Twilio and Stripe — 15 days. (2) Enforce MFA on all admin accounts and provide IdP configuration evidence — 30 days.

Within 90 days: (3) Deliver HIPAA-compliant IR plan with breach notification workflow. (4) Commission and deliver new penetration test summary. (5) Implement and document quarterly privileged access review program.

Re-assessment at 90-day mark. Provisional onboarding may proceed after items (1) and (2) are verified.